

WEB HACKING 101

WEB HACKING 101



Tolga Kabak

BU KİTAPÇIK İÇERİSİNDE WEB GÜVENLİK AÇIKLARINDAN BAHSETMEK İSTEDİM UMARIM İŞİNİZE YARAR...

- ❖-XSS
- ❖-OPEN REDIRECT
- ❖-CLICKJACKING
- ❖-CSRF
- ❖-IDOR
- ❖-SQL INJECTION
- ❖-BROKEN ACCES CONTROL
- RACE CONDITION
- INSECURE DESERIALIZATION
- XML (XXE) ATTACK
- SSTI
- RCE
- LDAP INJECTION

Bu demek oluyor ki web alanında sadece bu kadar güvenlik açığı var. Hayır ben bu yazıda TOP 13 zafiyeti ele aldım



XSS (Cross Site Scripting) script kodları üzerinden (genelde javascript) bir web sayfasına saldırı yapılmasıdır.

XSS çoğunlukla tarayıcıda saklanan bilgiler olan cookielere saldırı amacı ile kullanılmaktadır.

Örnek bir XSS saldırı kodu aşağıdadır. Bu kodda bir arama sayfasında html filtrelemesi yapılmazsa olabilecekler öngörülmüştür.

```
<a href="ornek.com/arama.php?deger=<script>alert("XSS TEST!")</script>">XSS testi için tıklayınız</a>
```

XSS testi için tıklayınız yazısına tıklandığında sanki arama textine `<script>alert("XSS TEST!")</script>` yazısı yazılması sağlanmaktadır. Eğer sitede XSS açığı varsa ekranda javascript alerti ile XSS TEST! Yazar.

Bu açıkları bulabilmek için Blogları, Forumları, Shoutboxları, yorum kutularını ve arama kutucuklarını deneyerek başlayabilirsiniz. Aslında burada bahsedilenlerden daha fazla örnek vermek mümkündür.

Google Dorkları daha kolay bulmak için kullanılabilir. Örnek liste :
<https://blog.softwaroid.com/2019/01/11/google-dorks-for-cross-site-scripting-xss/>

❖ **1 Stored (Persistent) XSS** (Saklanmış): En tehlikeli XSS saldırısı olan bu türde saldırıya izin veren kod sunucuda tutulur ve otomatik olarak yürütülür. Günümüz web tarayıcıları basit seviyede ki payload denilen bu zararlı kodların çoğunu engellemiş olsa da halen kullanılan kritik bir açıktır.

❖ **2 Reflected XSS** (Yansıtılmış): Bu durumda, kötü amaçlı kod sitenin kendisinde değildir, ancak daha önce saldırgan tarafından oluşturulan bir web bağlantısında yer alır. Yani dışarıdan alınan parametrelerin kontrol edilmeden ve işlenmeden alınan bu “kötü” kod parçasını işleyerek, site kullanıcının tarayıcısında istemeden veriyi kesecek veya XSS yüklemesinin kendisi kastedilmişse başka bir komut dosyası çalıştırabilir.

❖ **3 DOM (Self) XSS:** Öncelikle DOM Document Object Model ifadesinin kısaltılmasıdır. Web tarayıcıların çalışma anında yorumladığı her şeyi DOM kapsamaktadır. Sayfa kaynağında görüntülenmeyen zararlı kod sunucuya gönderilmediğinde, ancak tarayıcıda hemen çalıştırıldığında kullanılan bir yöntemdir.

Neler Yapabilirsin ?

Kullanıcının oturumuna müdahale (çerezler).

Gizli verileri çalmak için bir sayfanın değiştirilmesi (örneğin, bir giriş / şifre girişi formu).

Yüksek trafiğe sahip sitelerde komut dosyalarının uygulanması (reklam, görüntülemeleri artırma, DDoS saldırıları ve diğerleri için).

Görünüşte güvenli sitelerde kötü amaçlı yazılımların kullanılması.



OPEN REDIRECT

Open Redirect güvenlik açığı, bir uygulama, kullanıcının bir yönlendirmeyi kontrol etmesine veya başka bir URL'ye iletmesine izin verdiğinde oluşur. Uygulama, güvenilmeyen kullanıcı girişini doğrulamazsa, saldırgan, şüpheli olmayan bir kurbanı meşru bir etki alanından saldırganın kimlik avı sitesine yönlendiren bir URL sağlayabilir.

Saldırganlar, kimlik avı saldırılarına güvenilirlik katmak için açık yönlendirmelerden yararlanır. Çoğu kullanıcı meşru, güvenilir etki alanını görür, ancak kimlik avı sitesine yeniden yönlendirildiğini fark etmez.

Bu güvenlik açığı yasal uygulamayı her zaman doğrudan etkilemese de şirketin itibarı olumsuz etkilenebilir. Ek olarak, açık yönlendirmeler kuruluşun kendisi üzerinde yüksek bir etki gibi görünmeyebilir, kullanıcıların işletmede sahip oldukları güvene zarar vermemek önemlidir. Şunu belirtmekte fayda var ki, kendi sitenizdeki açık bir yönlendirme kendi çalışanlarınıza karşı çok iyi kullanılabilir!

OPEN REDIRECT ZAFİYETİ

- ❖ Encoded Redirection
- ❖ Url Encoded Redirection
- ❖ Base64 Redirection

Şeklinde alt başlıklara ayrılır

Bu Zafiyete Karşı Alınabilecek Önlemler :

Kullanıcılardan gelen veriler uygun şekilde filtrelenerek doğrulanmalıdır.

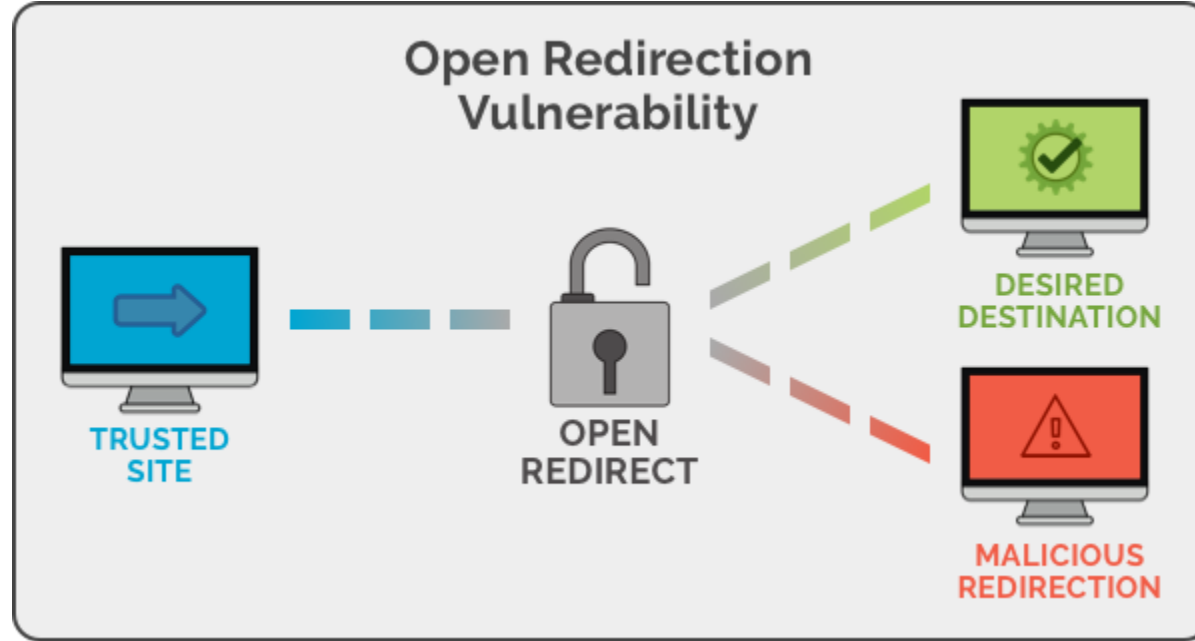
Geliştiriciler güvenilir URL adreslerinden oluşan listeler ile çalışmalıdır.

Web uygulaması, kullanıcı güvenilir olmayan bir URL'e yönlendirme yapmaya çalıştığında bir uyarı ile bunu bildirmelidir.

Geliştiriciler bir yönlendirme fonksiyonunu kullanmak yerine, özel linkler ile bağlantı kurmayı öncelik edinmelidir.

OPEN REDIRECT ZAFİYETİNİ DAHA İYİ ANLAMAK VE PRATİK YAPMAK İÇİN

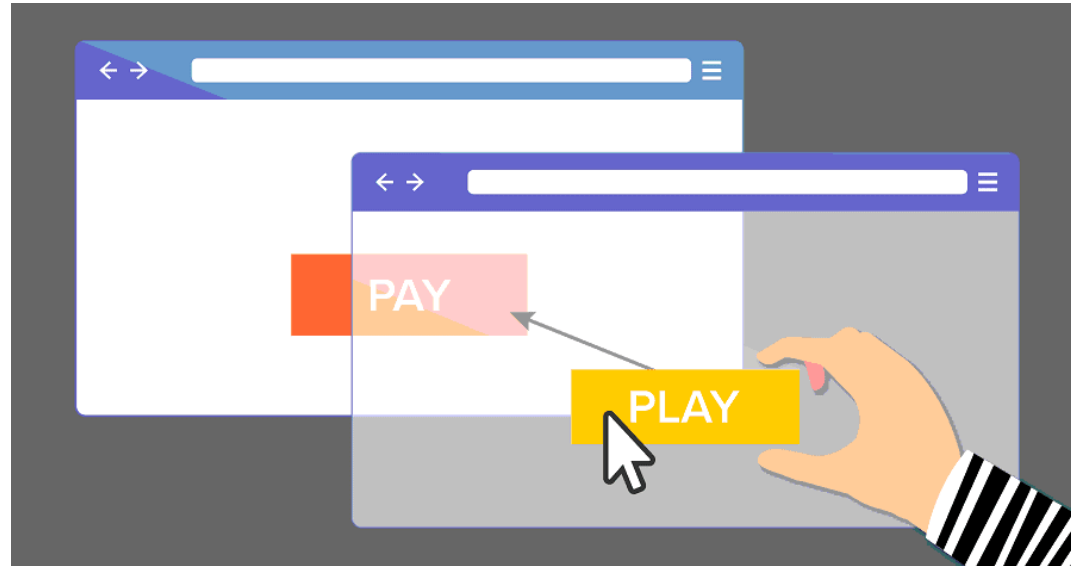
<https://bit.ly/portsw> adresine bakınız





CLICKJACKING

UI Redress Attack olarak da bilinen **Clickjacking** saldırısı sızma testlerinde sık karşılaşılan bir zafiyettir. Siber saldırgan, güvenli olarak görünen web sayfası kullanıcılarını güvensiz bir sayfaya yönlendirerek manipüle ettiği bu kullanıcıların işlem yapmasını hedef alır. Clickjacking'de sadece zararlı bir web sayfasına yönlendirmek dışında bir uygulamaya da yönlendirmeler görülmektedir. Clickjacking saldırısını uygulayan saldırgan, kullanıcı parolaları ve mail adresleri, banka hesap bilgileri gibi kritik bilgileri kolaylıkla elde edebilir.



Clickjacking amaçlarına ve faaliyetlerine göre farklı şekillerde sınıflandırılabilir:

- ❖ **Filejacking:** Saldırganın, kullanıcının yerelde sahip olduğu dosyalara erişim sağlamak için yaptığı saldırı yöntemidir.
- ❖ **Cookiejacking:** Kullanıcı arayüzünün, kurbanın tarayıcısında depolanan cookie gibi tanımlama verilerinin hedeflendiği saldırı yöntemidir.
- ❖ **Cursorjacking:** Arayüzdeki göstergenin, kurbanın hedeflediği başka bir konuma yönlendirilmesine dayalı bir yöntemdir.
- ❖ **Likejacking:** Kurbanın sosyal medya faaliyetlerini kontrol etmeyi amaçlamaktadır. Sosyal medyada bulunan bazı hesapların beğenilmesi, paylaşılması gibi faaliyetleri hedeflemektedir.
- ❖ **Password Manager Attacks:** Parola yönetim hesaplarındaki parola bilgilerinin saldırganlar tarafından belirtilmesine dayalı saldırı biçimidir.

Clickjacking saldırısını daha iyi anlamak ve pratik yapmak için aşağıda ki linki ziyaret ediniz

<https://bit.ly/portcsrf>



CSRF

CSRF (Cross Site Request Forgery) genel yapı olarak sitenin açığından faydalanarak siteye sanki o kullanıcıymış gibi erişerek işlem yapmasını sağlar.

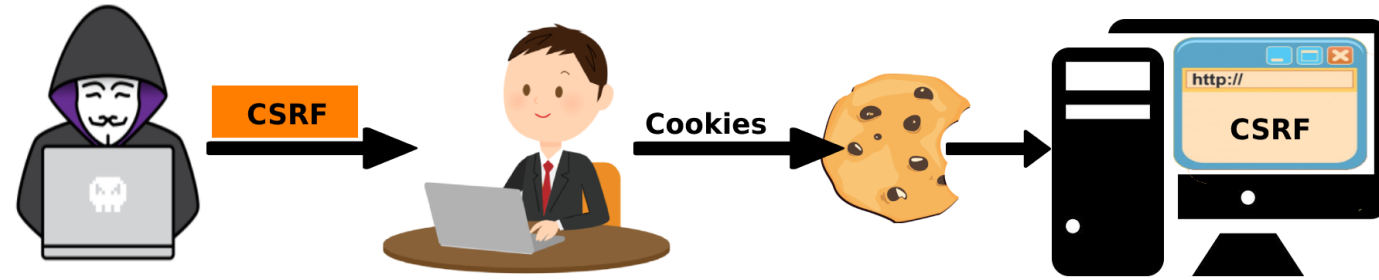
Genellikle GET requestleri ve SESSION işlemlerinin doğru kontrol edilememesi durumlarındaki açıklardan saldırganların faydalanmasını sağlamaktadır.

Aşağıdaki kodda saldırgan img etiketini kullanarak yani url'i bir imaj url'i olarak göstererek sisteme sanki daha önce kayıt olmuş bir kullanıcı gibi giriş yapmak istemektedir.

- ``
- Bu tür açıkları kapatmak için en pratik yol ise token kullanımıdır.
- `<?php`
- `$_SESSION["token"] = sha1(rand());`
- `echo '<a href="abc.php?giris=dogru&token='.$_SESSION["token"]."'>`
- `abc.php` dosyasındaki session kontrolü ise şu şekilde olmalıdır:
- `<?php`
- `if($_GET["giris"]==dogru){`
- `if(isset($_GET["token"])&&$_GET["token"]==$_SESSION["token"]){`
- `session_start();//Dogruysa oturumu baslat`
- `}`
- `else{`
- `echo "token yanlış!";`
- `}`
- `}`

CSRF saldırısını daha iyi anlamak ve pratik yapmak için aşağıda ki linke bakınız

<https://bit.ly/csrfvuln>





IDOR

Günümüzde Web uygulamalarında fazlaca görünen IDOR (**Insecure Direct Object References**) Web uygulamasında Yetkilendirme(authorization)'nin düzgün yapılandırılmamasından kaynaklanmaktadır.

Genelde Web sitelerinde kullanıcı hesapları numaralandırılarak kaydedilir. Örneğin “https://example.com/account/?userid=123” ve bu gibi durumlarda Authorization düzgün yapılandırılmadıysa Kötü niyetli bir kullanıcı kendi bilgilerini değiştirirken “userid” parametresine kendi id'sinden başka bir id tanımlayarak başka bir kullanıcının bilgilerini değiştirebilir.

• **IDOR ile Yapılabilecekler**

- ❖ Hesap Devralma.
- ❖ Hesap bilgileri değiştirme.
- ❖ Yetkisiz hesaplar ile yetkili kullanıcı gibi işlemler yapılabilir
- ❖ Dosya paylaşım sitelerinde izin olmayan dosyaları okumak.
- ❖ Başka kullanıcılar adına alışveriş yapmak.

• **IDOR Nerelerde Aranmalı**

- ❖ Web Uygulamalarının Hesap bilgileri bölümünde.
- ❖ Yazı, Resim, Video, Ses paylaşılabilen Her yerde.
- ❖ Yorum atılabilen Her yede.
- ❖ Kısacası POST ve PUT method'u ile yapılan nerdeyse tüm Requestlerde Ayrıca GET methodu ile yapılan download Requestlerinde aranabilir.

IDOR zafiyetini daha iyi anlamak ve pratik yapmak için bakınız :

<https://bit.ly/portidor>



SQL INJECTION

Kısaca SQL Injection saldırısı, web uygulamalarının **SQL** sorgularına **SQL** komutları enjekte edilmesi olarak tanımlanabilir. Başarılı bir **SQL injection saldırısı** kötü niyetli bir programcının bir web uygulamasının veri tabanına ulaşip onu yönetebilmesine imkan verir.

SQL Injection geniş kapsamlı ve çok tehlikeli bir saldırdır Mehmet Tuncer'in SQL Injection saldırısını anlattığı 19 sayfalık yazısına

<https://bit.ly/sqliv>

Bu linkten ulaşabilirsiniz

Ayrıca linkedin profilimde SQL map ve SQL injeciton hakkında yazımı bulabilirsiniz

Pratik Linki : <https://bit.ly/sqllabq>

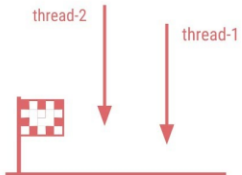


RACE CONDITION

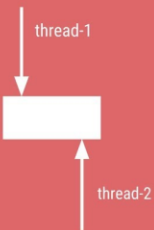
Race Condition, bir sistemin veya cihazın aynı kaynak üzerinden eş zamanlı olarak işlem yapmasıyla meydana gelir. Örneğin; Multithreading özelliği olan bir yazılımda, thread'ler birbirinden bağımsız bir şekilde ortak değişkene erişir ve değerini değiştirirse, devam eden süreçte her yerde aynı değere sahip olması olması gereken değişkenler, farklı thread'ler için farklı değerler ile işlemlerine devam edebilir. Buda istenmeyen sonuçlara neden olacaktır.

Daha iyi anlamak için : <https://bit.ly/portflp>

Race Conditions



Data Races





SSRF

Sunucu tarafı istek sahteciliği (SSRF olarak da bilinir), bir saldırganın sunucu tarafındaki uygulamayı, saldırganın seçtiği rastgele bir etki alanına HTTP istekleri yapması için manipüle etmesine olanak tanıyan bir web güvenlik açığıdır.

Tipik bir SSRF saldırısında, saldırgan sunucunun altyapısındaki dahili hizmetlere bağlantı kurmasına neden olabilir. Diğer durumlarda, sunucuyu rastgele harici sistemlere bağlanmaya zorlayabilir ve kimlik bilgileri gibi hassas verileri ele geçirebilirler.

SSRF de amacımız giden requesti manipüle edip içerideki bir servise erişmeyi sağlamak.

SSRF'te sunucunun bir isteği olması lazım sunucunun bir kaynağa ürettiği bir istek, serverin clint gibi davrandığı noktaların tamamı aklımıza gelmesi lazım.

Bu noktalara örnek verecek olursak;

- 3. parti bir adresten resim alma
- Verdiğimiz url den dosya alma indirme

SSRF saldırısını 3 Alt başlığa ayırabiliriz

❖ BLIND SSRF

❖ BASIC SSRF

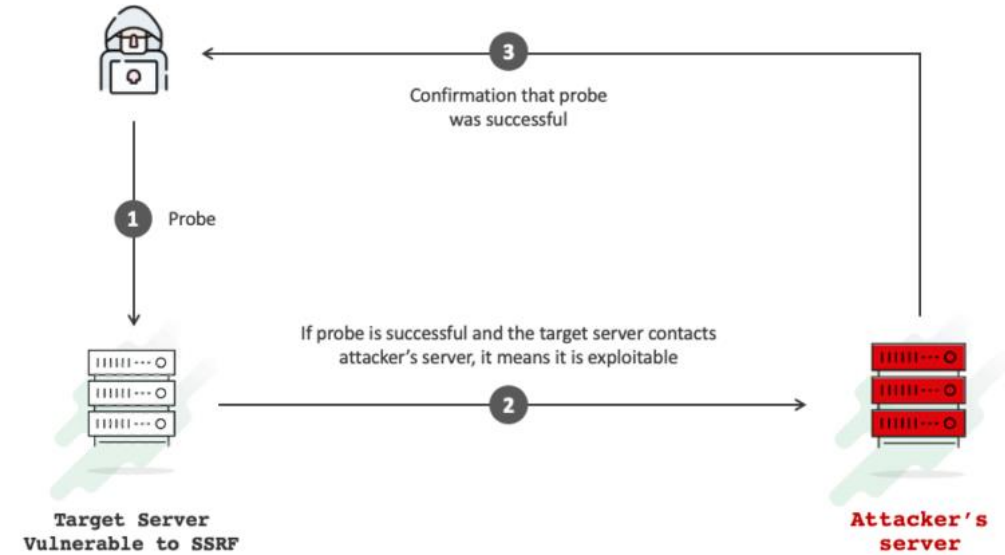
❖ OPEN REDIRECT ile SSRF

Daha iyi anlamak için bakınız :

<https://bit.ly/ssrfvuln1>

<https://bit.ly/ssrfvuln2>

<https://bit.ly/ssrfvuln3>





INSECURE DESERIALIZATION

Insecure Deserialization, kullanıcı tarafından kontrol edilebilen verilerin bir web sitesi tarafından seri durumdan çıkarılmasıdır. Bu , saldırganın zararlı verileri uygulama koduna geçirmek için serileştirilmiş nesneleri değiştirmesine olanak tanır.

Serileştirilmiş bir nesneyi tamamen farklı bir sınıftan bir nesneyle değiştirmek bile mümkündür. Endişe verici bir şekilde, web sitesinde mevcut olan herhangi bir sınıfın nesneleri, hangi sınıftan beklendiğine bakılmaksızın seri hale getirilecek ve somutlaştırılacaktır. Bu nedenle, Insecure Deserialization, bazen bir “nesne yerleştirme” güvenlik açığı olarak bilinir.

Beklenmeyen bir sınıfın nesnesi bir istisnaya neden olabilir. Ancak bu zamana kadar, hasar zaten yapılmış olabilir. Birçok seri durumdan çıkarma tabanlı saldırı, seri durumdan çıkarma tamamlanmadan önce tamamlanır.

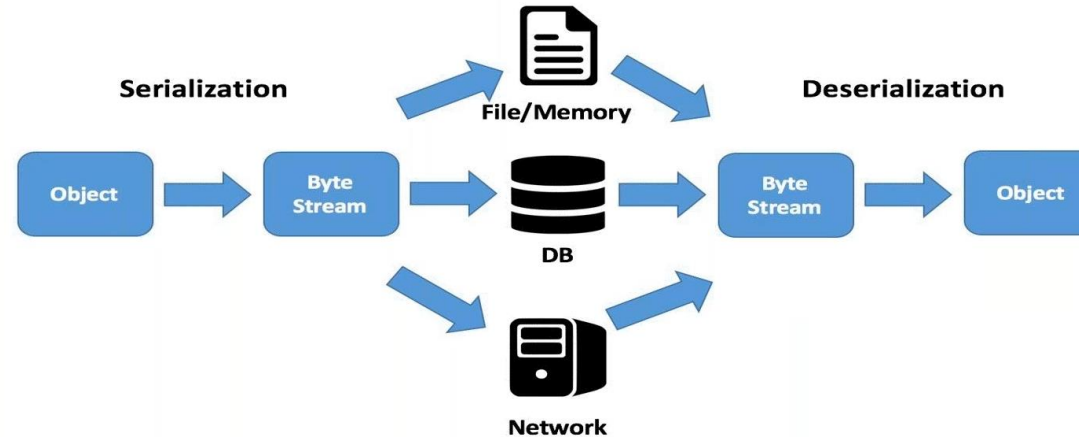
Bu , web sitesinin kendi işlevselliği kötü amaçlı nesneyle doğrudan etkileşime girmese bile, seri durumdan çıkarma işleminin kendisinin bir saldırı başlatabileceği anlamına gelir. Bu nedenle mantığı güçlü yazılan dillere dayanan web siteleri de bu tekniklere karşı savunmasız kalabilir.

Insecure Deserialization etkisi çok şiddetli olabilir, çünkü büyük ölçüde artırılmış bir saldırı yüzeyine bir giriş noktası sağlar. Saldırganın mevcut uygulama kodunu zararlı şekillerde yeniden kullanmasına izin vererek, genellikle uzaktan kod yürütme gibi çok sayıda başka güvenlik açığına neden olur.

Uzaktan kod yürütmenin mümkün olmadığı durumlarda bile, Insecure Deserialization, ayrıcalık yükselmesine, rastgele dosya erişimine ve hizmet reddi saldırılarına yol açabilir.

Bu zafiyeti daha iyi anlamak ve pratik yapmak için :

<https://bit.ly/portinsecure>





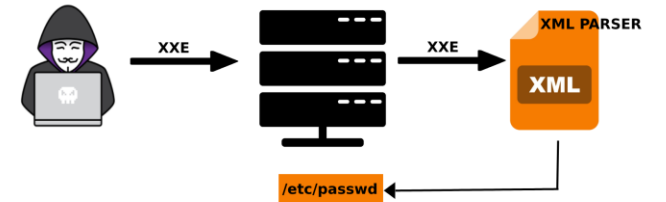
XML (XXE) ATTACK

XXE zafiyeti, sunucu(sunucu tarafında çalışan yazılım) **XML** verisini parse ederken özel olarak tanımlanmış bir XML varlığının çağırılması sonucu tetiklenir. Bazı XML kütüphaneleri özel olarak varlık tanımlamaya ve çağırmaya varsayılan olarak izin verirken bazılarında bu özellik kapalı gelir. Saldırının başarılı olabilmesi için hedef sistemde bu özelliğin aktif olması gerekir. Saldırıları, sistem tanımlayıcısındaki göreceli dizinler veya dosya şemaları kullanılarak parola ya da özel kullanıcı verileri gibi hassas veriler içerebilecek yerel dosyaları ifşa etmeyi içerebilir. XML belgesini işleyen uygulamaya ilişkin atak meydana geldiğinde, saldırgan bu güvenilir uygulamadan başka iç sistemlere geçmek ve muhtemelen başka iç sistem bileşenlerini http(s) istekleri üzerinden ifşa etmek veya korumasız herhangi bir iç servise bir **CSRF** saldırısı başlatmak için kullanabilir. Bazı durumlarda, istemci taraflı bellek bozulması sorunlarına zafiyeti bulunan bir XML işlemci kütüphanesi zararlı bir URL 'ye erişerek ve muhtemelen uygulama hesabı altında rastgele kod çalıştırılmasına izin vererek sömürülebilir.

XXE SALDIRISI ALT BAŞLIKLAR

- ❖ 1: Bir dosyanın içeriğini içeren harici bir varlığın tanımlandığı ve uygulamanın yanıtında döndürüldüğü dosyaları almak için XXE'den yararlanma.
- ❖ 2: Arka plandan giden bir URL'ye dayalı olarak harici bir varlığın tanımlandığı SSRF saldırılarını gerçekleştirmek için XXE'den yararlanma.
- ❖ 3: Gizli verilerin uygulama sunucusundan saldırganın kontrol ettiği bir sisteme iletildiği XXE verilerinin bant dışı sızdırılmasından yararlanma.
- ❖ 4: Hacker'ın hassas veriler içeren bir hata mesajını tetikleyebildiği hata mesajları yoluyla veri almak için XXE'den yararlanma.

Daha iyi anlamak ve pratik için : <https://bit.ly/xmlattack>





SSTi

SSDi (Server Side Template Injection) Web uygulamalarında dinamik verileri sunmak için kullanılan şablonlara beklenilenin dışında girdi eklenerek tetiklenen bir güvenlik zafiyetidir.

Neler Yapılabilir ?

Uzaktan kod çalıştırılabilir.

Dosya okuma-yazma, LFI/RFI, bilgi ifşası ve yetki yükseltme zafiyetleri tetiklenebilir.

Tespit Etme

Kullanıcıdan alınan değer doğrudan render ediliyorsa zafiyet var demektir. Twig için örnek verecek olursak: ilgili parametreye verilen “`{{7*7}}`” ifadesi “49” değerini veriyorsa zafiyet var diyebiliriz.

Zafiyetin İstismar Edilmesi

Örnek payload:

```
GET /ssti/ssti.php?name={{_self.env.registerUndefinedFilterCallback("shell_exec")}}{{_self.env.getFilter("dir")}} HTTP/1.1
```

Host: localhost

Bu payload girildiğinde sistem shell_exec fonksiyonunu çağırıp dir parametresini gönderip dosya ve dizinleri listeleyecektir.

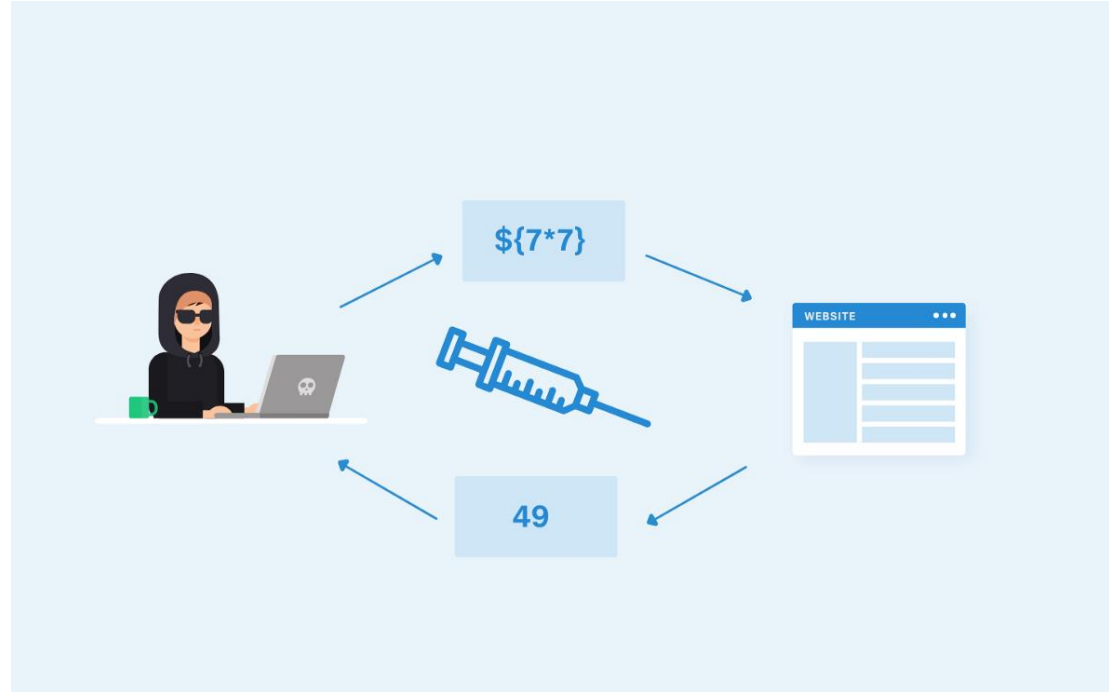
Ayrıca zafiyeti tespit etmek ve sömürmek için **tplmap** adlı tool kullanılabilir.

Önlemler

SSTI zafiyetine maruz kalmamak için kullanıcıdan alınan değer değil, önceden hazırlanmış **HTML** şablonu render edilmelidir.

SSTi Zafiyetini daha iyi anlamak ve pratik yapmak için bakınız :

<https://bit.ly/sstivuln>





RCE

Bu güvenlik açığı tüm türler arasında en tehlikelidir ve genelde 10 üzerinden 10 ile derecelendirilir. Bulmak zordur. Komut çalıştırma açığı aranan scriptte, komut çalıştıran bir kod parçası olması gerekir haliyle. Bu yüzden bulmak zordur, çünkü çok gerekmedikçe webmasterlar kolay kolay komut çalıştıran kodlar yazmaz. Ancak her sistemin her katmanında bu tip açıklara rastlanabilir. Biz burada web hacking'deki mevzusundan bahsedeceğiz.

Önce "**remote code execution**" ve "**remote command execution**" farklarından bahsedeceğim.

Remote code execution demek, script üzerinden kod çalıştırma açığı demek. Bilirsiniz eval() fonksiyonu ve bu fonksiyonla aynı mantıkla çalışan veya bünyesinde bu fonksiyonu çağıran fonksiyonlar remote code execution'a sebebiyet vermektedir. Eval desteği olan her web programlama dilinde karşılaşılabılır ve o script dilinde yazacağınız kodları çalıştırabilmenize imkan sağlar. Ama "**remote command execution**" farklıdır. Bu açık türü ise bu tür script dilleri üzerinden işletim sistemine yapılan çağrılar kullanır. Yani script kodları değil, doğrudan cmd/shell komutları çalıştırırsınız.

Önce php de sistem shell çağrısı yapan fonksiyonlara bakalım;

passthru()

exec()

shell_exec()

proc_open()

system()

popen()

`komut`

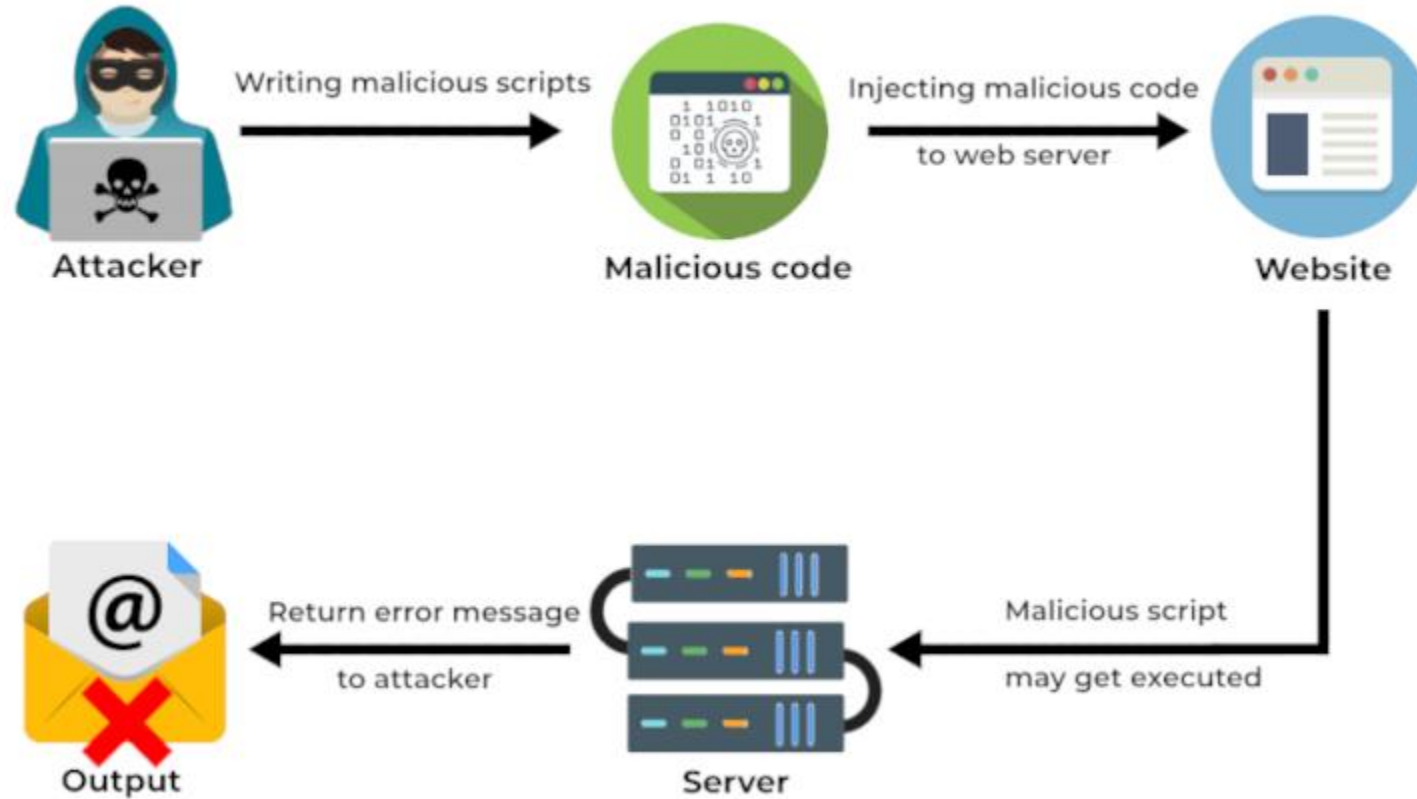
(` ve ` arasında yazılmış her şey shell_exec fonksiyonuna gönderilir. Genel olarak bunlar sistemde komut veya herhangi bir uygulama çalıştırmaya yarayan fonksiyonlardır.

Peki bu fonksiyonları webmaster ne gibi durumlarda kullanır?

Örneğin; whois, ping, traceroute gibi komutlar, pek çok domain ve network işlemlerini kolaylaştırabilir. Dolayısıyla bu gibi formlar arka planda sizden aldığı verileri önce shell komutuna gönderip daha sonra çıktıyı size iletiyor olabilir. Bu tabi sadece bir örnek, video dönüştürme, image process, debugging vs. vs. vs. daha pek çok sebeple bu gibi sistem çağrıları kullanılıyor olabilir.

RCE Zafiyetini daha iyi anlamak ve pratik yapmak için bakınız :

<https://bit.ly/rcevuln>





LDAP İNJECTION

Veritabanı sistemlerinde veriler istenilen yerde tutulabilirken dizin verilerinde hiyerarşik bir yapıda tutar (DNS hiyerarşisindeki gibi). Bu yapı arama ve okuma işlemlerinde normal veritabanlarına göre daha fazla performans sağlar. Kısa şekilde nedenlerinden bahsetmek gerekirse , normal veritabanlarında "Transaction" ve "Rollback" gibi işlemler desteklenirken , dizinde desteklenmez. Dizin işlemlerinde okuma işlevi daha ağır basar ve performans için kullanılmayan veriler gözardı edilebilir. Dizin işlemlerinde amaç , istenen bilgiye ulaşmaktır. Bilgilerin girişi sırasında herhangi bir kompleks algoritmaya ihtiyaç duymaz. Şu an bir farklı kaynaklardan farklı formlarda birçok dizin servisi bulunmaktadır. Önemlilerinden birkaçı:

DNS (Domain Name System) : Kısaca, internette kullanılan ilk dizin servsidir.

NIS , Active Directory , OID , Open Directory diyerek bu örnekler çoğaltılabilir.

LDAP çoğunlukla şirketlerde personel kayıtları , adres defteri , telefon rehberi vs. birçok hizmetin tek merkezli kullanılmasını sağlar. Örneğin bir adres defteri düşünün her mail servisinde bulunanlardan. Manuel olarak kendimize oluşturabiliriz ancak size daha önce mail göndermeyen dolayısıyla adresinizi bilmediğiniz birinin mailine nasıl ulaşabilirsiniz? Bunları bizim için sürekli güncelleyip kayıtları adres defterine tutacak bir şey var mı? Evet var. LDAP tam olarak bunu yapıyor. LDAP rahat şekilde filtreleme yapmanıza ve aradığınıza kolayca erişmenizi sağlar. LDAP'de mevcut kayıtlar için isimlendirmeler vardır:

- * Attributes
- * Values
- * Object Class

LDAP kayıtlarının kendilerini ayırt edecek şekilde isimlendirilmelerine Distinguished Name (DN) adı verilmiştir

LDAP kayıtları / cümleleri düzenli bir denetimden geçmediği uygulama & websitelerinde LDAP cümlelerinin kuruluşların değiştirilmesiyle yapılır.

LDAP Injection ile;

- Giriş formlarında SQL injectiondaki gibi şifresiz giriş yapılabilir
- Bilgilere erişim sağlanabilir ve değiştirilebilir
- Sıradan yetkiye sahip bir kullanıcı , kendini yetkilendirebilir.

LDAP injection saldırılarında mantık bi hayli basittir. Açıklaması biraz karmaşık gibi görünse de örnek verilerek rahatça anlatılabilir. Örneğin bir şirketin bünyesinde bulunan personel ve idareciler hakkında bilgilerin white pages olarak elektronik ortamda yayımlandığını varsayalım. Herhangi bir personelin bilgilerine ulaşmak için kullanılan arama modüllerinde yapılan sonuçları (kod olarak) genelde şu şekilde olur:

(&(Username=user) (Password=passwd)

Ve eğer yeterli güvenlik sağlanmamışsa saldırıya bi hayli açık haldedir. Örneğin user veya şifre kısmına herhangi bir şeyler yazarsak sorgu her zaman doğru dönecek ve sonuç şöyle olacaktır:

(&(Username=onur) (Password=redteam)

Buna benzer komutlar da iş görecektir. Örnek vermem gerekirse:

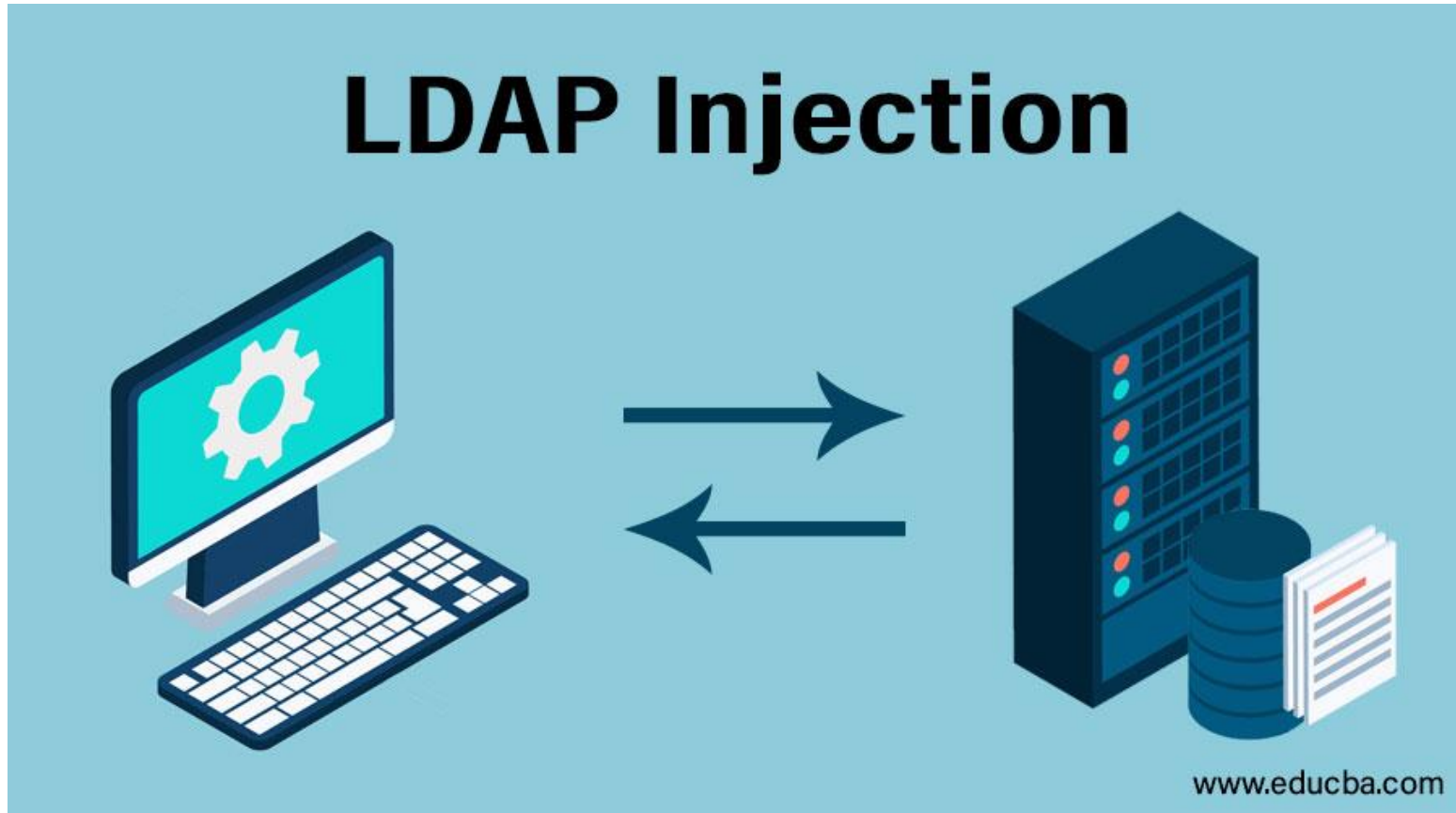
') (Username='validUsername') (&)) (

/') (Username=\ 'validUsername\') (&)) (

") ... Gibi devam ettirilebilir

Bu zafiyeti daha iyi anlamak için bakınız :

<https://bit.ly/ldapinj>





BROKEN ACCES CONTROL

Erişim kontrolü (veya yetkilendirme), teşebbüs edilen eylemleri veya talep ettikleri kaynaklara erişimi kimin (veya neyin) gerçekleştirebileceğine ilişkin kısıtlamaların uygulanmasıdır. Web uygulamaları bağlamında erişim kontrolü, kimlik doğrulama ve oturum yönetimine bağlıdır:

Kimlik doğrulama , kullanıcıyı tanımlar ve söyledikleri kişi olduklarını onaylar.

Oturum yönetimi , aynı kullanıcı tarafından hangi sonraki HTTP isteklerinin yapıldığını tanımlar.

Erişim denetimi , kullanıcının gerçekleştirmeye çalıştığı eylemi gerçekleştirmesine izin verilip verilmediğini belirler.

Bozuk erişim denetimleri, yaygın olarak karşılaşılan ve genellikle kritik bir güvenlik açığıdır. Erişim kontrollerinin tasarımı ve yönetimi, teknik bir uygulamaya iş, organizasyon ve yasal kısıtlamalar uygulayan karmaşık ve dinamik bir sorundur. Erişim kontrolü tasarım kararları teknoloji tarafından değil insanlar tarafından verilmelidir ve hata potansiyeli yüksektir.

Kullanıcı açısından bakıldığında, erişim kontrolleri aşağıdaki kategorilere ayrılabilir:

Dikey erişim kontrolleri

Yatay erişim kontrolleri

Bağlama bağlı erişim kontrolleri

Dikey erişim kontrolleri

Dikey erişim kontrolleri, diğer kullanıcı türleri için mevcut olmayan hassas işlevlere erişimi kısıtlayan mekanizmalardır.

Dikey erişim kontrolleri ile farklı tipteki kullanıcılar, farklı uygulama işlevlerine erişebilir. Örneğin, sıradan bir kullanıcının bu işlemlere erişimi yokken bir yönetici herhangi bir kullanıcının hesabını değiştirebilir veya silebilir. Dikey erişim kontrolleri, görevler ayrılığı ve en az yetki gibi iş politikalarını uygulamak için tasarlanmış güvenlik modellerinin daha ayrıntılı uygulamaları olabilir.

Yatay erişim kontrolleri

Yatay erişim kontrolleri, kaynaklara erişimi, bu kaynaklara erişmelerine özel olarak izin verilen kullanıcılarla kısıtlayan mekanizmalardır.

Yatay erişim denetimleriyle, farklı kullanıcılar aynı türdeki kaynakların bir alt kümesine erişebilir. Örneğin, bir bankacılık uygulaması, bir kullanıcının işlemleri görüntülemesine ve kendi hesaplarından ödeme yapmasına izin verir, ancak başka bir kullanıcının hesaplarına izin vermez.

Bağlama bağlı erişim kontrolleri

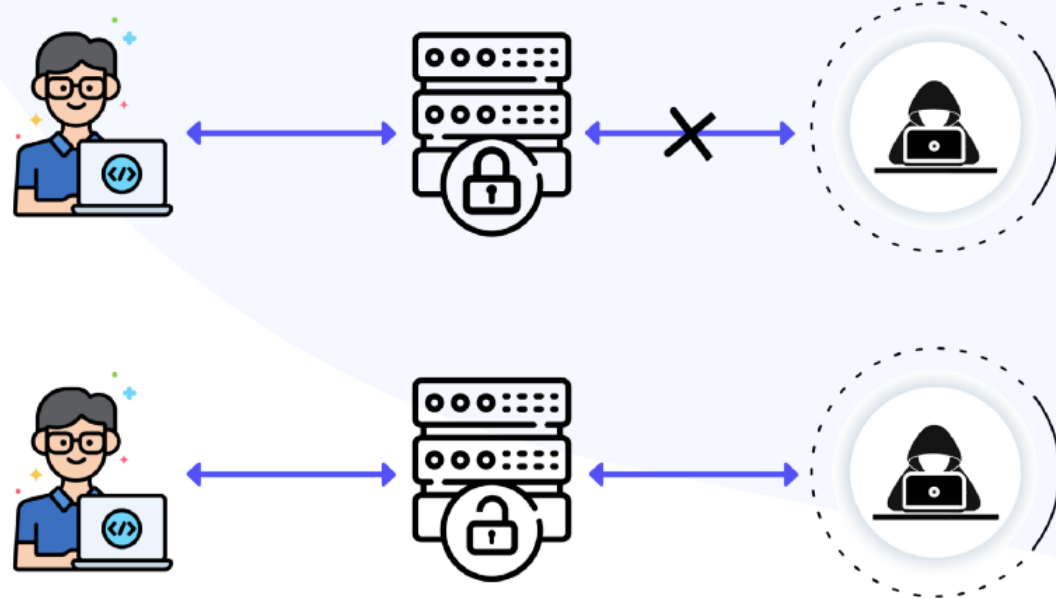
Bağlama bağlı erişim kontrolleri, uygulamanın durumuna veya kullanıcının onunla etkileşimine bağlı olarak işlevlere ve kaynaklara erişimi kısıtlar.

Bağlama bağlı erişim kontrolleri, bir kullanıcının eylemleri yanlış sırada gerçekleştirmesini engeller. Örneğin, bir perakende web sitesi, kullanıcıların ödeme yaptıktan sonra alışveriş sepetlerinin içeriğini değiştirmesini engelleyebilir.

Bu açığı daha iyi anlamak ve pratik yapmak için :

<https://bit.ly/brokenaccess>

Broken Access Control



SON

PRATİK LİNKLERİNE GÖZ ATMAYI UNUTMAYIN